Semsar API — Reply to the Flutter Team

To: Salamah · **From:** Aveno Code (backend) · **Date:** Nov 13, 2026 **Re:** "Simsar API — Requests to the Backend Team" (Nov 11, 2026)

Hi Salamah,

Thank you for the careful review. Every point you raised was correct. Here is where things stand:

- **Everything we accepted for v1 is built.** It is tested (215 automated tests, all passing) and pushed to `main`. `docs/API_CONTRACT.md` and `docs/API_REFERENCE.md` were updated in the same commits, so you can build from them now.
- **Not in v1:** M2 (SMS verification) and M8 (follow system). Please hide those screens for the first release.
- **M1 works differently from your suggestion.** Forgot password sends the code by **email**, not SMS (details below).
- **Still waiting on outside services:** C8 (Sham Cash) and C9 (Firebase).

None of this is live on simsar-sy.com until the server is updated. Section 1 explains how.

---

1. The live server (your section 1)

The `404` on `/governorates` happens because the server is running old code. The route has been in the repo for a while. After the latest `main` is uploaded, run these on the server from the project folder:

```
php artisan migrate --force
php artisan db:seed --force                          # base data; safe to re-run, never resets pa
php artisan db:seed --class=DemoDataSeeder --force   # test accounts + approved test ads
php artisan storage:link                             # only if not done before
php artisan optimize:clear
```

After that, every route in your list answers, including `/governorates`, `/ads/{id}/similar`, `/my/ads/stats`, `/ads/{id}/mark-sold`, `/ads/{id}/relist`, both `/report` routes and `/device-tokens`.

Test data (from `DemoDataSeeder`):

Account	Phone	Password
Seller (owns 6 approved ads with photos, 2 of them featured)	`0933000001`	`demo-pass-123`
Buyer (use it for favorites, chat and ratings)	`0933000002`	`demo-pass-123`

Two more things change on the server:

- **The root URL `/` now serves the public Semsar website.** The API itself is unchanged under `/api`. The old JSON status check moved to `/healthz`.
- **Password-reset emails need the server's mail settings in `.env`** (`MAIL_MAILER`, `MAIL_HOST`, `MAIL_PORT`, `MAIL_USERNAME`, `MAIL_PASSWORD`, `MAIL_FROM_ADDRESS`). A Hostinger mailbox works. If mail isn't set up, the endpoint still answers normally, but no email is sent.

---

2. Answer for every item

#	Answer	Notes
S1 rate limiting	✅ Done	120 requests/minute per user (or per IP when logged out) on all of `/api`. Login, register, forgot and reset allow 5/minute per phone-or-email + IP and 20/minute per IP. Over the limit you get `429` with a `Retry-After` header. Polling chat every 3–5 s is well inside the limit.
S2 phone/email exposure	✅ Done	`phone` and `email` are now **absent** (the keys are missing, not `null`) on every user except the account owner (and admins). A seller's phone appears only as `contact_phone` on an ad's detail (see C7).
S3 phone format	✅ Done	Numbers are stored as `09XXXXXXXX`. Register, login and reset accept any common spelling: `+963 999 111 222`, `00963…`, `963…`, `999111222`, dashes/spaces, Arabic digits. Numbers that aren't Syrian mobiles get a `422` on `phone`. Existing accounts were migrated to the same format.
S4 favorites status	✅ Done	`/favorites` lists only `approved` and `sold` ads.
S5 `rating_count` null	✅ Done	Always an integer.
S6 admin password	⏳ Deployment step	Can't be confirmed until the server is updated. Whoever has server access should log in at `/login` on the website with the admin phone, then use **Change password** on the profile page.
M1 forgot / reset password	✅ Done, **by email**	`POST /auth/forgot-password {phone}` or `{email}` emails a 6-digit code, valid for 30 minutes, to the email on the account. `POST /auth/reset-password {phone or email, code, password}` sets the new password and **revokes all tokens**, so log in again afterwards. The response is identical whether or not the account exists. Accounts without an email can't use it, so please show "contact support" in that case.

#	Answer	Notes
M2 SMS verification	❌ Not in v1	Please hide the screen. It needs a paid SMS provider.
M3 edit profile + avatar	✅ Done	Send `PUT/PATCH /auth/me` as JSON for text fields. **Use `POST /auth/me` with multipart for the avatar**, because PHP can't read multipart bodies on `PUT`. Fields: `name, email, governorate_id, city_id, avatar, remove_avatar`. Returns the user with `governorate` and `city`.
M4 change password	✅ Done	`POST /auth/change-password {current_password, password}`. The current token stays valid and other devices are signed out.
M5 delete account	✅ Done	`DELETE /auth/me {password}`. Deletes the user's ads, favorites, ratings and tokens. Conversations **stay** for the other person, with this user shown as `"مستخدم محذوف"` (Deleted user). New messages to a deleted user return `422`. The phone and email become free for a new sign-up.
M6 public profile	✅ Done	`GET /users/{id}`: name, avatar, governorate, city, rating, `created_at`, `active_ads_count`, `sold_ads_count`. Banned or deleted users return `404`.
M7 seller's ads	✅ Done	`GET /ads?user_id={id}`. Same shape and pagination as `/ads`.
M8 follow system	❌ Not in v1	Please hide those screens.
M9 mark conversation read	✅ Done	`POST /conversations/{id}/read` returns `{"data": {"marked": n}}`. Reading messages does **not** mark them read by itself.
M10 unread count	✅ Done	`GET /notifications/unread-count` returns `{"data": {"count": n}}`.
M11 rating summary	✅ Done	`GET /users/{id}/ratings/summary` returns `{"data": {"average", "count", "stars": {"5": n … "1": n}}}`.
C1 `is_favorited`	✅ Done	Included on every ad, everywhere. **Send the bearer token on public routes too.** Without it the value is always `false`.
C2 seller on list items	✅ Done	`user` (`id, name, avatar_url, rating_*`) is on every ad in every list.
C3 relations on favorites / my ads	✅ Done	`category`, `governorate`, `city`, `user` and `images` are on every list.
C4 location on the user	✅ Done	`register`, `login`, `GET /auth/me` and `PUT /auth/me` include `governorate` and `city`.

#	Answer	Notes
C5 conversation preview	✅ Done	Each conversation has `last_message {id, body, sender_id, created_at}` (or `null`) and `unread_count`.
C6 message polling	✅ Done	`?after_id={id}` returns only newer messages, oldest first, **unpaginated** (max 200). Use it for polling. `?order=desc` returns newest first, paginated. Calls with no parameters behave exactly as before.
C7 publish options	✅ Done	`is_negotiable`, `address`, `allow_chat` (default true), `allow_calls` (default true) and `hide_phone` (default false) work on create and update and appear on every ad. The ad detail adds `contact_phone`: the seller's number when calls are allowed and the phone isn't hidden, **for logged-in viewers only**, otherwise `null`. With `allow_chat: false`, starting a new conversation returns `422`. Changing only the three contact switches does **not** send the ad back for review.
C8 Sham Cash checkout	⏳ When ready	Still `501`, because we're waiting for Sham Cash API access. We plan to return `{"data": {"checkout_url": "..."}}` as you suggested, and will confirm when it's built.
C9 push notifications	⏳ Needs your app IDs	We'll create the Firebase project and send you `google-services.json` and `GoogleService-Info.plist`. Please send the **Android package name** and the **iOS bundle ID**.

3. Changes that may affect code you've already written

1. **Other users' `phone` / `email` keys are gone.** Use `contact_phone` from `GET /ads/{id}` for the call button.
2. **Register rejects non-Syrian numbers** with `422` on `phone`.
3. `429` **can now happen** on every route. The login screen is the one where users will realistically hit it.
4. **Reading a chat doesn't mark it read.** Call `POST /conversations/{id}/read` when the chat screen opens and after new messages arrive while it's open.
5. **Deleted users** show up as `"مستخدم محذوف"` in chats, their profile returns `404`, and sending them a message returns `422`.
6. **Reset password revokes every token**, so send the user back to login. Change password keeps the current token.
7. **Avatar upload must be `POST /auth/me`** (multipart), not `PUT`.

4. What we need from you

- The **Android package name** and **iOS bundle ID** for Firebase (C9).
- Confirmation that the **M2 and M8** screens are hidden for v1.
- Tell us if any field or route name doesn't suit the app. We'll rename it and update the two docs in the same commit, as before.

Thanks again. The review made the API noticeably better.

— Aveno Code